INFORME DE AUDITORÍA INTERNA DE SEGURIDAD: BOTIUM TOYS

→ **Rol Simulado:** IT Security Auditor / Compliance Analyst

→ **Organización Simulada:** Botium Toys (Empresa minorista y de comercio electrónico)

→ **Contexto Formativo:** Proyecto práctico basado en una actividad propuesta en el Certificado de Ciberseguridad de Google.

→ **Naturaleza del Proyecto:** Auditoría interna simulada con fines educativos, desarrollada sobre el caso de estudio de Botium Toys.

→ **Marco de Referencia:** NIST Cybersecurity Framework (NIST CSF)

Alcance de la Auditoría (Scope)

El alcance de esta auditoría abarca la totalidad del programa de seguridad de la organización, comprendiendo los activos tecnológicos, los equipos de los empleados (dispositivos de usuario final y estaciones de trabajo remotas), la red interna, los sistemas de comercio electrónico, los servicios empresariales, el almacenamiento de datos, las instalaciones físicas y los sistemas heredados administrados por el departamento de TI.

Objetivos (Goals)

- Evaluar la postura de seguridad actual de la organización utilizando el Marco de Ciberseguridad del NIST (NIST CSF).
- Identificar y documentar los riesgos, vulnerabilidades y brechas existentes en los controles administrativos, técnicos y físicos.
- Verificar el cumplimiento de normativas y estándares clave aplicables a la empresa, tales como PCI DSS, GDPR y marcos SOC Tipo 1 y Tipo 2.
- Proveer recomendaciones priorizadas al departamento de TI para mitigar riesgos, asegurar la continuidad del negocio y proteger la información sensible de clientes y empleados.

Evaluación de Riesgos (Risk Assessment)

- **Puntuación de Riesgo Global:** 8 / 10 (Riesgo Alto), debido a la deficiente gestión de activos, la falta de controles técnicos esenciales y el incumplimiento de normativas internacionales de protección de datos.
- **Impacto Potencial:** Considerado alto en términos de pérdida de activos, exposición de información de identificación personal (PII/SPII), datos de tarjetas de pago y posibles sanciones regulatorias.

- **Hallazgos Clave y Brechas Identificadas**
    - **Control de Accesos:** Ausencia de controles adecuados basados en el principio de Mínimo Privilegio y Separación de Funciones, lo que permite que los usuarios dispongan de permisos superiores a los necesarios.
    - **Protección de Datos:** Ausencia de cifrado para los datos de tarjetas de pago y deficiencias en la clasificación e inventario de datos personales, identificadas durante la evaluación de controles y cumplimiento.
    - **Respuesta y Recuperación:** Ausencia de un Plan de Recuperación ante Desastres (DRP) y de copias de seguridad.
    - **Detección:** Falta de un Sistema de Detección de Intrusos (IDS) para identificar actividades sospechosas en la red.

Lista de Verificación de Controles (Controls Assessment Checklist)

A continuación se detalla el estado de implementación de los controles de seguridad evaluados:

Control de Seguridad	¿Implementado?	Tipo y Categoría
Principio de mínimo privilegio (Least Privilege)	No	Administrativo / Preventivo
Planes de recuperación ante desastres (DRP)	No	Administrativo / Correctivo
Políticas de contraseñas (Password Policies)	Sí	Administrativo / Preventivo
Separación de funciones (Separation of Duties)	No	Administrativo / Preventivo
Firewall	Sí	Técnico / Preventivo
Sistema de detección de intrusos (IDS)	No	Técnico / Detectivo
Copias de seguridad (Backups)	No	Técnico / Correctivo
Software antivirus	Sí	Técnico / Preventivo
Mantenimiento de sistemas heredados (Legacy Systems)	No	Técnico / Preventivo
Cifrado (Encryption)	No	Técnico / Disuasorio
Sistema de gestión de contraseñas (Password Manager)	Sí	Técnico / Preventivo
Cerraduras (oficinas, tienda y almacén)	Sí	Físico / Preventivo
Sistema de videovigilancia (CCTV)	Sí	Físico / Preventivo-Detectivo
Sistema de prevención de incendios (alarmas, rociadores)	Sí	Físico / Detectivo-Preventivo

Lista de Verificación de Cumplimiento (Compliance Checklist)

Estado de cumplimiento frente a los estándares regulatorios evaluados:

PCI DSS (Estándar de Seguridad de Datos para la Industria de Tarjetas de Pago)

- Acceso exclusivo de usuarios autorizados a datos de tarjetas: **No cumple.**
- Almacenamiento, procesamiento y transmisión en entorno seguro: **No cumple.**
- Procedimientos de cifrado implementados para transacciones: **No cumple.**
- Políticas seguras de gestión de contraseñas aplicadas a datos de pago: **No cumple.**

GDPR (Reglamento General de Protección de Datos)

- Privacidad y protección de datos de clientes de la UE: **Cumple.**
- Plan de notificación de brechas de seguridad dentro de las 72 horas: **Cumple**.
- Clasificación e inventario correcto de datos: **No cumple**.
- Políticas, procedimientos y procesos de privacidad documentados: **Cumple**.

SOC Tipo 1 y SOC Tipo 2 (Controles de Sistemas y Organizaciones)

- Políticas de acceso para usuarios: **No cumple**.
- Confidencialidad y protección de datos sensibles (PII/SPII): **No cumple**.
- Integridad de los datos (consistentes, completos y precisos): **Cumple**.
- Disponibilidad de los datos para personas autorizadas: **Cumple**.

Recomendaciones de Seguridad (Security Recommendations)

Basado en los hallazgos de la auditoría, se recomiendan las siguientes acciones prioritarias para fortalecer la postura de seguridad de Botium Toys:

1. Implementar el Principio de Mínimo Privilegio y Separación de Funciones: Restringir los accesos de los empleados exclusivamente a la información y sistemas necesarios para sus funciones, disminuyendo el riesgo de abuso de privilegios o exposición de datos sensibles.

2. Establecer Cifrado de Datos: Adoptar medidas de cifrado robustas para proteger la información confidencial y los datos de tarjetas de crédito durante su almacenamiento, procesamiento y transmisión.

3. Instalar un Sistema de Detección de Intrusos (IDS): Incorporar herramientas de monitoreo de red para detectar oportunamente actividades sospechosas o intentos de acceso no autorizado.

4. Desarrollar Copias de Seguridad y Planes de Recuperación (DRP): Automatizar respaldos periódicos y estructurar un plan de recuperación ante desastres para garantizar la continuidad operativa ante fallas o ciberataques.

5. Centralizar la Gestión de Contraseñas: Consolidar una solución de administración de credenciales que asegure el cumplimiento estricto de los requisitos de complejidad en toda la organización.